Pagemark 0.7.0 audit report, with 0.7.1 fix status

Release readiness - Pagemark 0.7.0

Audited commit `045e8147c28780fd03dd0f714cce9d0225071f13` (tag v0.7.0), 2026-10-12. Mobile-leaning full audit.

Verdict: READY WITH CONDITIONS

0 BLOCKER, 0 CRITICAL, 6 HIGH, 17 MEDIUM, 41 LOW, 20 INFO (84 findings, see FINDINGS.md). Nothing loses data on a normal path, the 193-test suite passes from a fresh clone twice, and the signed release builds and runs. The six HIGH findings are on failure paths, but two of them (PGM-100, PGM-200) affect the promises the app makes about restore and lock, so fix or knowingly accept them before calling 0.7.x done.

Status after the fix pass (2026-10-12, version 0.7.1, local commits 6052bc8..8ca6bbe)

All 6 HIGH findings and 15 of the 17 MEDIUM findings are fixed in code with new tests (suite now 206 tests, analyzer clean). They are marked READY FOR VERIFICATION in FINDINGS.md: the auditor has not yet re-run the original scripts against the fixes, and several need a real phone (FLAG_SECURE in recents, Keystore reset, Drive, updater). Not fixed, by decision or scope: PGM-110 (shelf names are global, a design change), PGM-108 (undo import leaves extra reads), 22 LOW and 12 INFO items listed in FINDINGS.md.

Verified on the emulator after the fixes: the 0.7.1 sideload release installs over 0.7.0 with the 5,000-book library intact, the font-2.0 filter chip is no longer clipped, no runtime errors in logcat. Release files built by `tool/build.ps1` are signed with the release key (SHA-1 39:04:59:AD...:27:F7), and the Play bundle has no installer permission.

Verdict now: **READY WITH CONDITIONS** for a 0.7.1 release once the real-device checks in MANUAL_TEST_PLAN.md pass.

HIGH findings as found (fix unless accepted)

ID	One line	Verify with
PGM-100	The "safety copy kept in the app" after a restore/import has no way to be restored in the UI	add a restore-from-safety-copy action; manually restore twice and recover the first state
PGM-101	PIN lockout overflows (negative at 300 fails, 0 s from 320), so attempt limiting stops	`scripts/pgm_engine_audit_test.dart` case K-lockout-overflow
PGM-102	Changing the backup passphrase does not trigger a new upload	change passphrase, run backup, expect a new file
PGM-103	restoreDb and safetyCopy have no tests	the new tests exist and run in `flutter test`
PGM-200	A secure-storage reset leaves no lock config; gate offers "Set a PIN" and opens	`scripts/pgm200_securestorage_loss_test.dart`
PGM-202	After that reset, scheduled Drive backups upload unencrypted with no warning	backup refuses or notifies when the passphrase key is gone

Suggested direction: PGM-101 `steps >= 7 ? 3600 : 30 * (1 << steps)` (lock.dart:98); PGM-200/202 set `resetOnError: false` and treat a missing key as "storage lost", fail closed and notify; PGM-102 clear `bk_hash` in `setPassphrase` (backup.dart:145).

Coverage

Area	Result
Automated suite (fresh clone, x2)	193 pass, 1 skip by design, analyzer clean, generated code current
Smoke / launch (release x86_64, emulator)	first launch OK; cold 1.3 s at 5k books
Scale (5,000 books, restore via picker)	OK, ~120 MB PSS, Stats correct
Data safety / engine / hostile input	script-driven, 33 findings, rest passed (see findings_part_data.md)
Security / packaging / docs / compat	static + APK inspection, 44 findings; signing and assets verified
Mobile emulator passes	font scale 2.0 (PGM-001), landscape inconclusive (PGM-004)

Area	Result
Real device	NOT RUN (see MANUAL_TEST_PLAN.md)

Top risks

1. Lock/backup trust after a Keystore reset (PGM-200, 202, 204).
2. Restore is the one destructive path and it is the least tested (PGM-100, 103, 104-106).
3. Docs promise things the code does not do (PGM-203, 240-243, 248).

Findings register - Pagemark 0.7.0 (audited commit 045e8147)

IDs are permanent. Found: HIGH 6, MEDIUM 17, LOW 41, INFO 20 (total 84).

Fixes for the items marked READY FOR VERIFICATION are on main (local commits 6052bc8..8ca6bbe, version 0.7.1) and are covered by new tests; they still need the auditor's verify pass and, where marked in MANUAL_TEST_PLAN.md, a real-device check. Still open: MEDIUM 2, LOW 22, INFO 12.

Source parts: findings_part_mobile.md, findings_part_data.md, findings_part_sec.md. Repro scripts in scripts/.

ID	Sev	Category	Component	Finding	Evidence	Fix commit	Status
PGM-001	LOW	Accessibility	Library filter chips	At system font scale 2.0 the "All" status chip text is clipped at the bottom (chip height does not grow with text); other chips scroll horizontally and are fine.	auditor (shots/c_font2.png)	8ca6bbe	READY FOR VERIFICATION
PGM-002	LOW	UX	Empty library	The empty state shows both an "Add a book" button and the "Add book" FAB, two controls for one action.	auditor (shots/a_first_launch.png)	8ca6bbe	READY FOR VERIFICATION
PGM-003	INFO	Packaging	Release assets	Only arm64 and armv7 APKs are published; x86_64 emulators cannot install the release. Release behaviour was verified on a locally built, release-signed x86_64 APK.	auditor		OPEN
PGM-004	INFO	Compat	Orientation	Landscape/tablet layout NOT SEEN: the emulator did not rotate the app when user_rotation=1 was set, and the manifest has no screenOrientation lock. Needs a real device or a rotating emulator.	auditor		OPEN
PGM-005	INFO	Tests	bulk_test	Three "tap() missed hit test" warnings in the bulk-selection tests; tests pass but the taps may not hit the intended widget.	auditor (suite1.log)		OPEN

ID	Sev	Category	Component	Finding	Evidence	Fix commit	Status
PGM-006	INFO	Positive	Restore / scale	Restore of a 5,000-book backup works through the picker; dialog counts are correct; locked-books/PIN message is correct; cold start 1.3 s and ~120 MB PSS at 5k books; Stats totals exclude locked books as designed.	auditor		VERIFIED
PGM-100	HIGH	Data safety	export.dart:241-286, backup_page.dart:45, import_ui.dart:133	The restore/import "safety copy kept in the app (newest 3)" cannot be restored from anywhere in the UI (USER_MANUAL.md:299 promises it)	code	f272ec6	READY FOR VERIFICATION
PGM-101	HIGH	Security	lock.dart:98	PIN lockout integer overflow: `30*pow(2,n~/5-1)` goes negative at 300 failures and is 0 s from 320; counter resets only on success, so attempt limiting silently stops	script pgm_engine_audit_test [K-lockout-overflow]	6052bc8	READY FOR VERIFICATION
PGM-102	HIGH	Data safety	backup.dart:145,157	Changing the backup passphrase does not change the upload signature (`bk_hash` not cleared), so scheduled backups skip; Drive keeps only old-passphrase backups	code (not run against Drive)	6052bc8	READY FOR VERIFICATION
PGM-103	HIGH	Test coverage	export.dart restoreDb, safetyCopy	No tests in the repo for restore and safety copy (destructive path)	code	f272ec6	READY FOR VERIFICATION

ID	Sev	Category	Component	Finding	Evidence	Fix commit	Status
PGM-104	MEDIUM	Data safety	export.dart restore	Failure after the DB swap (e.g. cover import) shows "restore failed" but the live file is already replaced and the connection closed	script [R-fail-after-swap]	f272ec6	READY FOR VERIFICATION
PGM-105	MEDIUM	Data safety	export.dart safetyCopy	Safety-copy names have minute resolution; a second restore/import in the same minute overwrites the first restore point	script [R-safety-copy-collision, R-pre-import-collision]	f272ec6	READY FOR VERIFICATION
PGM-106	MEDIUM	Data safety	export.dart inspect()	No column checks: id-only tables or user_version 0 pass inspection, then fail to open after the swap	script [D-inspect-no-column-check, D-inspect-user-version-0]	f272ec6	READY FOR VERIFICATION
PGM-107	MEDIUM	Robustness	export.dart:163-176	unpack has no size cap and decompresses ignored entries in memory; a 537 KB zip uses 120 MB RAM and disk	script	f272ec6	READY FOR VERIFICATION
PGM-108	MEDIUM	Data safety	importer	Undo import leaves reads/quotes added to existing books and created shelves	script [I-undo-addreads, I-undo-shelves]		OPEN
PGM-109	MEDIUM	Data safety	CSV/JSON export-import	Round trip loses series_number, current_page, description, cover	script [RT-*-lossless]	a8f05d4	READY FOR VERIFICATION
PGM-110	MEDIUM	Privacy	shelves	Shelf names are global; vault shelf names show in main-library chips/picker	script [V-leak[shelf names]]		OPEN
PGM-111	MEDIUM	Privacy	book_extras.dart: 219-235	Covers page counts locked books and "Save all" downloads vault covers into the plain covers folder	code (UI not run)	6fdb6b8	READY FOR VERIFICATION

ID	Sev	Category	Component	Finding	Evidence	Fix commit	Status
PGM-112	LOW	Robustness	importer	Raw UnsupportedError on NaN/Infinity/1e400 in year/pages/minutes cells; TypeError for non-list JSON `books`	script	a8f05d4	READY FOR VERIFICATION
PGM-113	LOW	Engine	date parsing	Lenient ISO dates (02-30 becomes 03-02, month 13 rolls, offset shifts day, years 0001/9999)	script	a8f05d4	READY FOR VERIFICATION
PGM-114	LOW	Robustness	export.dart	Zip entry `covers/.` throws raw PathAccessException and leaks the temp dir	script		OPEN
PGM-115	LOW	Engine	covers	removeUnused race can delete a just-saved cover	code		OPEN
PGM-116	LOW	Engine	importer	Same ISBN with different titles merged silently	script		OPEN
PGM-117	LOW	Engine	Goodreads import	Read-shelf row without Date Read gets finished = Date Added	script		OPEN
PGM-118	LOW	Engine	CSV	Leading tab/CR gains an apostrophe; text starting `'=` loses it on round trip	script		OPEN
PGM-119	LOW	Robustness	updater.dart	Raw TypeError for non-list assets; missing tag_name becomes release "null"	script	a8f05d4	READY FOR VERIFICATION
PGM-120	LOW	Robustness	import	`pagemark_export` as string/double bypasses the newer-format guard	script	a8f05d4	READY FOR VERIFICATION
PGM-121	LOW	Engine	compareVersions	int64 overflow gives 0; `-rc` suffix ignored	script	a8f05d4	READY FOR VERIFICATION
PGM-122	LOW	Engine	Stats pace	Off by one day in the first hour after midnight under DST; 365 constant	script (expression replicated)		OPEN
PGM-123	LOW	Engine	series number	Accepts NaN/Infinity; 1e20 displays 9223372036854775807	script		OPEN

ID	Sev	Category	Component	Finding	Evidence	Fix commit	Status
PGM-124	LOW	Security	lock.dart	Concurrent checkPin undercounts failures (6 attempts count as 2)	script	6052bc8	READY FOR VERIFICATION
PGM-125	LOW	Engine	backup passphrase	Not Unicode-normalised (same visible passphrase can fail to decrypt)	code		OPEN
PGM-126	LOW	Robustness	bulk ops	40,000-id bulk operation raises "too many SQL variables"	script		OPEN
PGM-127	LOW	Engine	undo	Undo of mark-finished deletes a created read the user has since edited	code		OPEN
PGM-128	LOW	Engine	dates	Stored as instants; a timezone change shifts the finished date	code		OPEN
PGM-129	LOW	Robustness	lookup.dart	`byIsbn` has unguarded infinite paging, nameless suggestions, FormatException on bad bodies (UI shows a generic snackbar)	code		OPEN
PGM-130	INFO	Engine	duplicates	Trashed titles are invisible to duplicate check and import; shelf names can differ only by case	code		OPEN
PGM-131	INFO	Privacy	watchQuoteText	Carries vault quote text into main-screen state (not displayed)	code		OPEN
PGM-132	INFO	Security	updater	Update download with no size/sha has no integrity check (see PGM-209)	code	a8f05d4	READY FOR VERIFICATION
PGM-133	LOW	Data safety	export.dart	Crash window between DB rename and cover import	code	f272ec6	READY FOR VERIFICATION

ID	Sev	Category	Component	Finding	Evidence	Fix commit	Status
PGM-200	HIGH	Security	lock.dart, lock_ui.dart	Default `FlutterSecureStorage()` has `resetOnError` on; a Keystore failure wipes all keys, so the vault gate and whole-app lock offer "Set a PIN" and open without the old PIN	script pgm200_securestorage_loss_test.dart	6052bc8	READY FOR VERIFICATION
PGM-201	MEDIUM	Privacy	log.dart, import_ui.dart, backup.dart	Diagnostics log can hold titles/notes: sqlite exceptions embed bound parameters and `Log.e/w` write raw exceptions	script pgm201_log_param_leak_test.dart	6fdb6b8	READY FOR VERIFICATION
PGM-202	HIGH	Security	backup.dart:146-176	Backup encryption depends on `bk_pass` in secure storage; after the same wipe scheduled Drive backups silently upload plaintext (locked books included) with no notification	code	6052bc8	READY FOR VERIFICATION
PGM-203	MEDIUM	Privacy	privacy.dart:30-38	Plaintext exports and picked backups persist in `cache/share_plus` and `cache/file_picker`, which `cleanTempExports` never touches; contradicts manual section 8 and IB-10 "fixed"	code (plugin sources; not run on device)	6fdb6b8	READY FOR VERIFICATION
PGM-204	MEDIUM	Security	ui.dart:172-187 VaultPage	`dispose` clears FLAG_SECURE on pause for the hidden-tab vault; unverified	code	6052bc8	READY FOR VERIFICATION
PGM-205	LOW	Security	lock.dart, crypto_backup.dart	PBKDF2 150k iterations, 8-character passphrase minimum	code		OPEN
PGM-206	LOW	Security	lock.dart, app_lock.dart	Lockout and delay use wall-clock time (clock change bypasses)	code		OPEN

ID	Sev	Category	Component	Finding	Evidence	Fix commit	Status
PGM-207	LOW	Security	ui.dart:1344-1350	Remove lock leaves the app-lock pref on and the vault open to anyone	code	6052bc8	READY FOR VERIFICATION
PGM-208	LOW	Security	lock_ui.dart:84	Recovery code copied to clipboard and never cleared	code	6052bc8	READY FOR VERIFICATION
PGM-209	LOW	Security	updater.dart:117, 133-156	Asset URL host/scheme not validated; digest check skipped when absent	code	a8f05d4	READY FOR VERIFICATION
PGM-210	LOW	Privacy	backup.dart:186-189	Temp snapshots not deleted on failure	code	6fdb6b8	READY FOR VERIFICATION
PGM-211	LOW	Privacy	tool/backup-to-nas.ps1, CLAUDE.md, LICENSE	Public repo shows NAS IP/share name, keystore location, owner's full name	auditor (git grep)		OPEN
PGM-212	INFO	Security	repo, history, APK, PDFs	Secret scans clean	script pgm200_apk_scan.py		VERIFIED
PGM-213	LOW	Release	privacy.dart:19	`PAGEMARK_SCREENSHOTS` value cannot be proven from the binary; no release guard	code	6fdb6b8	READY FOR VERIFICATION
PGM-214	INFO	Security	backup.dart	Drive backups are plaintext by default (design)	code		OPEN
PGM-215	LOW	Robustness	export.dart:128-150	Zip entries read fully into memory	code		OPEN
PGM-216	INFO	Security	manifest	Manifest review OK	auditor (aapt2)		VERIFIED
PGM-217	INFO	Privacy	network	Outbound hosts match PRIVACY.md	code grep, APK strings		VERIFIED
PGM-220	INFO	Release	release assets	Signing, digests, versionCodes verified	script pgm220_release_verify.sh		VERIFIED
PGM-221	INFO	Release	signing	v2-only signature; one off-PC key copy	auditor (apksigner)		OPEN
PGM-222	MEDIUM	Release	release process	No release script; README output name `app-armeabi-v7a-release.apk` does not match the `armv7` name the updater needs; `tool\build.ps1` missing	code updater.dart:70-83	6fdb6b8	READY FOR VERIFICATION
PGM-223	LOW	Release	ci.yml	Debug build only, no release job, floating tags	code		OPEN

ID	Sev	Category	Component	Finding	Evidence	Fix commit	Status
PGM-224	LOW	Hygiene	pubspec	Unused riverpod; `+eol` sqlite3_flutter_libs	auditor	a8f05d4	READY FOR VERIFICATION
PGM-225	LOW	Hygiene	gradle.properties	Windows tmpdir in committed jvmargs	code		OPEN
PGM-226	INFO	Release	native libs	16 KB alignment OK	script pgm220_release_verify.sh		VERIFIED
PGM-227	INFO	Release	updater	x86_64 not published	code		OPEN
PGM-228	INFO	Release	R8 mapping	Kept local only	auditor		OPEN
PGM-229	LOW	Hygiene	repo	`android/.kotlin` untracked; stale User-Agent `Pagemark/0.3`	auditor	a8f05d4	READY FOR VERIFICATION
PGM-231	INFO	Data	db.dart	Migrations 1 to 4 complete; prefs/secure keys inventoried	code		VERIFIED
PGM-240	MEDIUM	Docs	INSTALL_MANUAL	Says 0.5.0 and "no notification permission"; manifest has POST_NOTIFICATIONS	auditor (aapt2)	8b18d68	READY FOR VERIFICATION
PGM-241	MEDIUM	Docs	PACKAGE_OVERVIEW	Stale: schema 3, "not minified", "no failure notification", SQLCipher on roadmap	code	8b18d68	READY FOR VERIFICATION
PGM-242	MEDIUM	Docs	DRIVE_SETUP	Claims backups are "not encrypted by Pagemark"	code	8b18d68	READY FOR VERIFICATION
PGM-243	MEDIUM	Docs	manual 8/15, PRIVACY	"Temp exports deleted" and "log never has titles" are false on failure paths (see PGM-201/203)	cross-ref	8b18d68	READY FOR VERIFICATION
PGM-244	LOW	Docs	CLAUDE.md	Stale permission list and roadmap; missing `tool\build.ps1`	code		OPEN
PGM-245	LOW	Docs	screenshots	Version-stamped images are 0.4.1-0.5.0	auditor		OPEN
PGM-246	LOW	Docs	README, ROADMAP	"330" backlog is actually 430 entries	auditor	8b18d68	READY FOR VERIFICATION
PGM-247	LOW	Docs	USER_MANUAL	Section numbering out of order	code		OPEN
PGM-248	MEDIUM	Docs	ROUNDING_OUT	"Fixed" claims untrue or partial for IB-10, IB-16, IB-80, IB-44	code	8b18d68	READY FOR VERIFICATION

ID	Sev	Category	Component	Finding	Evidence	Fix commit	Status
PGM-249	LOW	Docs	manual section 8	Remove-lock description incomplete	code	8b18d68	READY FOR VERIFICATION
PGM-250	LOW	Compat	ui.dart:39	Dates en_US, 12-hour clock, no localisation	code		OPEN
PGM-251	INFO	Compat	manifest	English-only; RTL moot	code		OPEN
PGM-252	LOW	Docs	INSTALL_MANUAL:27	Unknown-sources step is Android 8+ only (minSdk is 24)	code	8b18d68	READY FOR VERIFICATION
PGM-253	INFO	Compat	edge-to-edge / predictive back	NOT RUN	-		OPEN
PGM-254	INFO	Compat	tablet / multi-window	NOT RUN	-		OPEN

Manual test plan - what a human must still do (on a real phone)

Ordered by risk. Nothing here was run by the audit.

- [ ] **Restore twice, recover the first state** (PGM-100). Restore a backup, restore a second one within a minute, look for any way back. Pass: the original library is recoverable.
- [ ] **FLAG_SECURE and recents** (PGM-204). Open the hidden Locked tab, press Home, open recents. Pass: the thumbnail is blank.
- [ ] **Fingerprint unlock** on a real device: unlock, cancel, wrong finger, fingerprint added after setup.
- [ ] **Drive sign-in and scheduled backup**: sign in, run now, wait one scheduled cycle, restore from the Drive file. Pass: file appears, size matches, restore works.
- [ ] **Passphrase change** (PGM-102): change the backup passphrase, run backup, check a new file appears and decrypts.
- [ ] **Updater install**: from 0.6.0 install 0.7.0 through Settings > Updates. Pass: installs over the top, data intact, same signing certificate.
- [ ] **Battery managers / Doze**: on a phone with an aggressive battery manager (Samsung, Xiaomi), confirm scheduled backups still run after two days.
- [ ] **Notifications**: deny and re-grant the permission; backup-failure notification shows.
- [ ] **Storage full**: fill storage, try an export and a restore. Pass: clear error, library untouched.
- [ ] **Shared exports left behind** (PGM-203): export CSV, share it, inspect `cache/share_plus` (needs a debug build or adb on a rooted device).
- [ ] **Landscape and tablet/foldable** (PGM-004, 254): rotate every main screen; check split-screen.
- [ ] **TalkBack**: add a book, rate it, open Settings with TalkBack on; icon buttons have names.
- [ ] **Edge-to-edge and predictive back** (PGM-253) on Android 14/15/16.
- [ ] **Large font / display size** on a phone (PGM-001): font 2.0 and largest display size on Library and Book pages.
- [ ] **Offline use**: airplane mode, add a book by hand, open covers, run lookup. Pass: no crash, clear message.
- [ ] **Real timezone change** (PGM-128): finish a book, change timezone, check the date.
- [ ] **iOS**: not built yet; everything above is Android only.

Audit status - Pagemark 0.7.0

- Repo: C:\Project Folder\Pagemark, branch main, audited commit `045e8147c28780fd03dd0f714cce9d0225071f13` (tag v0.7.0), working tree clean at start.
- OS: Windows 11 Pro; Flutter 3.47 at C:\dev\flutter; JDK 25 (needs `-Djdk.net.unixdomain.tmpdir=C:/tmpj`); Android emulator x86_64.
- Suite from fresh clone: 193 pass + 1 skip, twice (33 s, 20 s). `flutter analyze` clean. build_runner output matches committed code.
- Real user data to avoid: none touched. Emulator used throughout; scratch data under the session scratchpad.
- Mode: full, mobile-leaning. Prefix PGM. Mine PGM-001..099, data agent 100..199, security agent 200..299.

Phase log

Phase	State
0 Baseline	done
1 Feature inventory	folded into FEATURE_MATRIX notes in the agents' files; no separate matrix written
2 Suite audit	done (counts above); per-module coverage not measured
3 Smoke	done on release x86_64 (first launch, 5k restore, cold starts)
4 GUI	partial: font 2.0, landscape attempt, library/stats/settings seen; full activation sweep NOT RUN
5 Data safety	done by script (findings_part_data.md)
6 Engine	done by script
7 Hostile input	done by script
8 Security	done (SECURITY_AUDIT.md)
9 Performance	done on emulator (PERFORMANCE_BASELINE.md)
10 Packaging	done (RELEASE_ENGINEERING_AUDIT.md)
11 Docs truth	done (DOCS_TRUTH.md)
12 Compat	static only (COMPAT_MATRIX.md)
13 Report	RELEASE_READINESS.md, MANUAL_TEST_PLAN.md, FINDINGS.md written

Not written

DATA_SAFETY_MATRIX.md, ENGINE_AUDIT.md, HOSTILE_INPUT.md, FEATURE_MATRIX.md, GUI_MATRIX.md, NAVIGATION_MATRIX.md, TEST_COVERAGE.md: the data agent could not write report files and its results live in findings_part_data.md and its scripts; the GUI/feature matrices were not produced.

NOT RUN

Everything in MANUAL_TEST_PLAN.md: real device, fingerprint, Drive, WorkManager/Doze, updater install, TalkBack, tablets, iOS.

Performance baseline - Pagemark 0.7.0

Audited commit `045e8147`. Build: signed release, x86_64 (local build, `flutter build apk --release --target-platform android-x64`, release key SHA-1 matches the published APKs). Device: Android emulator (x86_64, 898x2000 preview), not a real phone. Numbers are a baseline to diff next release, not a promise for real hardware.

Scenario	Result	Notes
Cold start, empty profile	2026 ms (`am start -W`)	first launch
Warm start, empty profile	1931 ms	
Cold start, 5,000-book library	1297 / 1273 / 2394 ms (3 runs)	restored via Settings > Restore
Restore of 5,000 books / 5,011 reads / 1,667 quotes (1.45 MB)	dialog shows correct counts; completed without error	message about 100 locked books and PIN is correct
Memory, 5k library, after scrolling	PSS 116-130 MB, RSS 221-232 MB	no growth seen over 15 fast scrolls
Stats tab, 5k library	renders within the 4.4 s tap-to-screenshot window	numbers correct: 4,900 tracked (5,000 minus 100 locked)
Synthetic data generation	5,000 books in 6.8 s	test-only

Not measured

- Frame time / jank: `dumpsys gfxinfo` reports 0 frames for a Flutter surface, so scroll smoothness was judged by screenshots only. NOT RUN: profile-mode timeline on a real device.
- Search and skin-switch latency at 5k: not timed (no scripted driver); a manual stopwatch pass is in MANUAL_TEST_PLAN.
- Battery drain, WorkManager wake behaviour, thermal: need a real device over hours.
- 50k-book library: not generated (5k is already above any realistic personal library).

Pagemark 0.7.0 - Security audit (phase 8)

Auditor: security/release-engineering auditor. Commit `045e814` (tag `v0.7.0`). Finding IDs PGM-200..PGM-217 (permanent). Evidence key: `script <name>` (in `docs/release-audit/scripts/`), `auditor` (run by me this session), `code <file:line>` (read only). No `lib/`, `test/`, `android/`, `pubspec.yaml` or existing docs were modified. No emulator/adb, no NAS, `key.properties` and the keystore were not read.

Summary

Sev	Count	IDs
HIGH	2	PGM-200, PGM-202
MEDIUM	3	PGM-201, PGM-203, PGM-204
LOW	9	PGM-205..PGM-211, PGM-213, PGM-215
INFO	4	PGM-212, PGM-214, PGM-216, PGM-217 (positive confirmations / design notes)

Both HIGH findings share one root cause: `FlutterSecureStorage()` is constructed with default options (`lock.dart:14`, `backup.dart:142`) and in `flutter_secure_storage` 11.2.0 the Android default is `resetOnError = true`, i.e. if the Keystore-wrapped key cannot decrypt, **every** stored key is silently deleted. Everything that protects the vault (mode, pin_hash, rec_hash, fails, lock_until) and the backup passphrase (`bk_pass`) lives there.

Findings

PGM-200 HIGH - Lost secure storage turns the PIN/app lock into "choose a new PIN" and opens the vault

- **Repro (script):** `flutter test docs/release-audit/scripts/pgm200_securestorage_loss_test.dart` - with empty secure storage the `LockGate` shows "Set a PIN" (and `LockService.mode()` is null) instead of refusing. Passing the dialog calls `onUnlock`.
- **Expected:** a library that has locked books and a configured lock must never fall back to the "first-time setup" state without the old credential; at minimum the app should detect "locked books exist but no lock config" and stay closed (or force Restore/Reset with a loud warning).
- **Actual:** `LockService.mode()` returns null -> `LockGate` (lock_ui.dart:195-205) offers "Set a PIN" / device lock and unlocks. The whole-app lock (`appLockEnabled` is a plain SharedPreferences bool) shows the same gate, so it is also bypassed.
- **Trigger:** any secure-storage reset: Keystore key invalidation / corruption on some OEMs, OS upgrade quirks, key-store wipe. `allowBackup=false` removes the restore-from-backup trigger but not the others. Likelihood low-to-moderate, consequence total (vault and app lock open to whoever holds the phone).
- **Cause:** `FlutterSecureStorage()` default options (`lock.dart:14`); no "locked books exist" cross-check; lock state is only in secure storage. The package default `resetOnError: true` is at `flutter_secure_storage-11.2.0/lib/options/android_options.dart:51`.
- **Suggested fix:** pass `AndroidOptions(resetOnError: false)` and treat a read exception as "locked, unknown" (fail closed, show "secure storage unavailable"); keep a non-secret marker in SharedPreferences/DB (`lock_configured=true`) so "marker set but mode null" is detected and routes to an explicit recovery screen (recovery code can no longer work, so the only honest path is "erase locked library or keep it unreadable"). Add a test next to `data_safety_test.dart`.
- **Verify:** the script above must fail (gate must not show "Set a PIN" when the marker is set).

PGM-202 HIGH - Same wipe silently downgrades scheduled Drive backups to plaintext, locked books included

- **Repro (code):** set a passphrase (`bk_pass`), enable automatic backup, lose secure storage (see PGM-200). `DriveBackup.run` (backup.dart:158-176) reads `passphrase()`, gets null and uploads `pagemark-*.zip/.sqlite` unencrypted; the signature `...|plain` differs from `...|enc`, so it re-uploads immediately. No notification, no `bk_err`; the only trace is the toggle showing "off" on the backup page (`backup_page.dart:93`).
- **Expected:** a backup job that was configured as encrypted must fail closed ("passphrase missing - open Pagemark") rather than upload plaintext; the user said "locked books are in every backup".

- **Impact:** privacy: the entire library incl. locked books, quotes, thoughts leaves the phone in the clear to Google Drive; the 5 retained copies rotate out the encrypted ones.
- **Cause:** "encrypted" is not a stored setting, it is the *presence* of `bk_pass` (backup.dart:146-148, 161-176).
- **Fix:** persist `bk_encrypt=true` in SharedPreferences when a passphrase is set; in `run()` if `bk_encrypt` and no passphrase -> throw `BackupAuthException` (notify: "your backup passphrase is missing; backups are paused").
- **Verify:** unit test with `FlutterSecureStorage.setMockInitialValues({})` + `bk_encrypt=true` expects an exception and no `files.create` call.

PGM-201 MEDIUM - Diagnostics log can contain book titles / thoughts (promise "never" is false on failure paths)

- **Evidence:** `script pgm201_log_param_leak_test.dart` prints `SqliteException(2067)... Causing statement: INSERT INTO "shelves" ("name") VALUES (?), parameters: MY-SECRET-SHELF-NAME`. sqlite3 3.x `SqliteException.toString()` embeds bound parameters; Drift wraps them. Call sites that interpolate the raw exception: `import_ui.dart:42,55` (Log.e), `backup.dart:46,201`, `log.dart:75,79` (global Flutter/async handlers), `lookup.dart:87`.
- **Impact:** an import/write failure (or any uncaught DB error, including on locked books) writes titles/authors/notes/thoughts into `pagemark.log`; Settings -> Diagnostics tells the user to **Copy** it when asking for help, and CLAUDE.md/PRIVACY.md/manual §15 state it never holds book data.
- **Fix:** in `Log.e/w` redact: log `e.runtimeType` plus `SqliteException.message/resultCode` only; strip anything after "Causing statement". Add a test that logs the exception above and asserts the secret is absent.

PGM-203 MEDIUM - Plaintext copies of exports/backups survive in cache sub-folders that the "wipe" never touches

- **Evidence:** `code share_plus-13.3.1/.../Share.kt:239,297-304` copies every shared file into `cacheDir/share_plus/<name>`; it is deleted only by the *next* share call (`:119,287`). `file_picker` (android_file_picker-2.0.1 `FileUtils.kt:713-757`) copies every picked file (restore backup, import CSV) into `cacheDir/file_picker/<ts>/`; it is cleared only by `clearTemporaryFiles()`, which the app never calls (`grep clearTemporaryFiles lib` = empty). `cleanTempExports` (privacy.dart:30-38) only iterates top-level **files** in the cache dir.
- **Impact:** an unencrypted "Export database file" (includes locked books, thoughts) or a decrypted/picked backup stays readable in app cache indefinitely, contradicting manual §8 ("temporary export files are deleted") and ROUNDING_OUT IB-10 "fixed". Private app storage, so exposure = root/adb on rooted/debug phones, device backups of cache excluded; still a stated guarantee that is not met.
- **Fix:** in `cleanTempExports` also delete `cache/share_plus` and `cache/file_picker` recursively, and call it right after share/restore/import complete (not only on relock). **Verify:** device: export unencrypted DB, `adb shell run-as` not available on release; instead add a unit test around the helper with a temp dir.
- *Not tested on a device (adb off-limits to me); behaviour read from plugin source.*

PGM-204 MEDIUM - FLAG_SECURE can be dropped on `paused` for the hidden-tab vault (needs device check)

- **Evidence:** `code ui.dart:172-176` - `VaultPage.dispose()` calls `Secure.set(false)` unconditionally when it was unlocked; `didChangeAppLifecycleState(paused)` (`ui.dart:183-187`) with delay 0 runs `wipeLockedTraces()` -> `popUntil(first)` -> dispose. The documented gotcha (CLAUDE.md "FLAG_SECURE ordering") says the flag must stay on until `resumed`; the tab version honours it (`ui.dart:96,101`), the hidden-tab version clears it immediately and does not check `appLocked`.
- **Impact:** between pause and the recents snapshot the vault screen may be captured unprotected (pop animation). Unverified - the device auditor should long-press-"Library" vault -> Home -> Recents and screenshot the card.
- **Fix:** drop `Secure.set(false)` from `VaultPage.dispose` (let `resumed` in Home clear it) or guard with `appLocked`.

LOW findings

- **PGM-205 LOW (crypto parameters).** PBKDF2-HMAC-SHA256 at 150,000 iterations for the PIN (lock.dart:16), recovery code, and backup container (crypto_backup.dart:16). OWASP 2023 guidance is 600,000 for SHA-256. Backup passphrase minimum is 8 characters (`backup_page.dart:137`, `ui.dart:1272`), so a stolen Drive `.pgbak` is brute-forceable offline for weak passphrases. Mitigations present: random 16-byte salt per file (so key differs per file -> the random 96-bit GCM nonce cannot repeat under one key), constant-time compare (`lock.dart:155-162`), authenticated header-less GCM (wrong passphrase/tamper ->

WrongPassphrase). Suggest 600k + store the iteration count in the container (new magic PGMKENC2) and a 10+ char/strength meter. code.

- **PGM-206 LOW (clock).** Lockout (lock_until) and the lock-after-delay (app_lock.dart:62-66, ui.dart:95-103) use wall-clock DateTime.now(). Setting the system clock forward clears a PIN lockout; setting it back keeps the vault open past the delay. Needs the phone unlocked + Settings access, so LOW. Use Stopwatch/monotonic elapsed where possible. code lock.dart:77-81,95-102.
- **PGM-207 LOW ("Remove lock").** Remove lock (ui.dart:1344-1350) clears the credentials but leaves app_lock (prefs) true, so the next launch shows a gate that offers "Set a PIN" to anyone; and locked books stay in the vault open to whoever sets the new PIN (subtitle says so). By design for the vault, but the whole-app lock should be switched off with it, and the removal confirmation should say the locked books will be readable by anyone. Related: ROUNDING_OUT IB-16 listed as fixed. code.
- **PGM-208 LOW (clipboard).** The recovery code dialog has a **Copy** button (lock_ui.dart:84) that puts the 80-bit PIN-bypass secret on the system clipboard and never clears it (clipboard history/keyboards/other apps pre-Android 13 can read it). Also quotes copy to the clipboard by design. Suggest clearing after ~60 s or marking ClipDescription.EXTRA_IS_SENSITIVE. code.
- **PGM-209 LOW (updater hardening).** Updater.download (updater.dart:133-156) takes browser_download_url from the JSON with no scheme/host check, follows redirects, and silently skips the SHA-256 check when the asset has no digest (updater.dart:117). Trust model (INFO): digest and file come from the same GitHub channel, so the digest only detects corruption, not a hostile release; the real integrity guarantee is Android refusing an APK signed with a different key than the installed one - this holds because all releases share certificate SHA-1 39:04:...F7 (PGM-220). Downgrade is not possible (compareVersions, available needs latest > current; Android also refuses a lower versionCode). Suggest: require https + host in {github.com, objects.githubusercontent.com, release-assets.githubusercontent.com}, and show "unverified" when no digest. code.
- **PGM-210 LOW (backup temp files on failure).** DriveBackup.run deletes snap/upload only on success (backup.dart:186-189); on any error the plaintext snapshot (with locked books) stays in cache until the next foreground launch (ui.dart:62). Wrap in try/finally. code.
- **PGM-211 LOW (public-repo privacy).** The repo is PUBLIC (gh repo view): tool/backup-to-nas.ps1:15 and CLAUDE.md:99 publish the home NAS address \\192.168.1.204\Apocrypha_Main_Pool\Libary_Pool\APP Projects\PageMark, and the script's README text states that the signing keystore **and key.properties with plaintext passwords** are kept on that share ("the ONLY copy outside this PC"). RFC1918 address, no credentials in the repo, so LOW; it tells an attacker where the release key lives. Also in history (git log -S"Apocrypha": 254b1b5, 2a12a91), so removal needs a history rewrite - not recommended; consider parameterising the default path (env var) going forward. LICENSE:3 carries the owner's full name (owner's call). script pgm200_apk_scan.py + auditor git grep.
- **PGM-213 LOW (documentation-build switch).** Secure._docBuild = bool.fromEnvironment('PAGEMARK_SCREENSHOTS') (privacy.dart:19) is compile-time only (not settable at runtime, no --dart-define-from-file in repo). I could not prove the shipped APK was built without it: the constant is folded so neither the name nor the value appears in libapp.so (script pgm200_apk_scan.py: name found only in the bundled CHANGELOG text). There is no release script/CI guard to make shipping it impossible. Verify behaviourally on a device (locked screen screenshot must be black) and add a tool/ release script that refuses PAGEMARK_SCREENSHOTS in its define list.

INFO (positive confirmations and design notes)

- **PGM-212 INFO - secrets scan clean.** Repo HEAD, full history (25 commits, git log --all -S for storePassword=, BEGIN ... PRIVATE, AIza, .jks blobs: no keystore or key.properties ever added; the -S key.properties/.jks hits are text mentions in docs/gradle), the three published APK sets and docs PDFs (pgm230_pdf_scan.py) contain no keys, passwords, owner email, local paths. Only personal strings: NAS path (PGM-211) and name in LICENSE. Screenshots (docs/screenshots, 5 viewed + names) show invented sample books/Open Library covers only; no account e-mail. .gitignore covers *.jks, *.keystore, key.properties, local.properties; git ls-files shows none. script pgm200_apk_scan.py.
- **PGM-214 INFO - Drive backup plaintext by default (design).** Encryption is opt-in; locked books travel in every backup; documented in-app and in PRIVACY. Matches CLAUDE.md non-negotiable wording. Consider requiring a passphrase before "Automatic backup" can be switched on.
- **PGM-215 LOW (zip handling).** Exporter.unpack is zip-slip safe (exact pagemark.sqlite, cover names must match ^[A-Za-z0-9._-]{1,80}$ and no ..; extracted into a fresh temp dir; export.dart:128-150, covers.dart:33) but reads each entry fully into memory (entry.readBytes()), so a hostile zip with a huge entry can OOM the app during restore preview. code.
- **PGM-216 INFO - manifest review (release APK Pagemark-0.7.0-arm64.apk, aapt2 dump xmltree).** allowBackup=false, fullBackupContent=false, dataExtractionRules excludes root/file/database/sharedpref/external for cloud-backup and device-

transfer; not debuggable; no `usesCleartextTraffic` and no network-security-config (targetSdk 36 default = cleartext blocked); `extractNativeLibs=false`. Only exported own component: `MainActivity` (launcher, no custom intent filters, so no deep-link/ACTION_SEND data injection). Exported library components are all permission-gated stock ones (`profileinstaller` receivers need `DUMP`, `SystemJobService` needs `BIND_JOB_SERVICE`, Google `RevocationBoundService`). FileProviders (image_picker, open_filex, share_plus) all `exported=false`, `grantUriPermissions=true`; share_plus path = `cache/share_plus/` only; the open_filex provider declares `root-path "."`, `files-path`, `cache-path` and external paths (broad, but only reachable through URIs the app itself grants - the app passes only the downloaded update APK). Permissions and justification: INTERNET (lookup/updates/Drive), CAMERA (scanner; `uses-feature camera required=false`), USE_BIOMETRIC / USE_FINGERPRINT (androidx.biometric legacy), REQUEST_INSTALL_PACKAGES (in-app updater; fine for side-loaded distribution, would block Play), POST_NOTIFICATIONS (backup-failure notice), and merged from WorkManager/plugins: VIBRATE, WAKE_LOCK, ACCESS_NETWORK_STATE, RECEIVE_BOOT_COMPLETED, FOREGROUND_SERVICE + FOREGROUND_SERVICE_SHORT_SERVICE (service type 0x800 = shortService, consistent). READ_MEDIA_* / READ_EXTERNAL_STORAGE correctly removed (CLAUDE.md gotcha holds). `queries`: PROCESS_TEXT, GET_CONTENT. `auditor`.
- **PGM-217 INFO - network inventory matches the docs.** Outbound hosts (grep + APK strings): `openlibrary.org` (search, ISBN, works - user typed text/ISBN), `covers.openlibrary.org` (and whatever `cover.large` host Open Library returns, normally archive.org) for cover images (also for locked books at display time: IP + ISBN visible to Open Library; PRIVACY covers "when a cover is shown"), `api.github.com` (daily release list), GitHub release-asset CDN (redirect from `github.com/.../releases/download`, not named in PRIVACY.md), Google (`accounts.google.com`/Play services sign-in, `www.googleapis.com` Drive v3, scope exactly `drive.appdata`). No analytics/crash SDKs in the dependency list. Tokens are fetched per run via `authorizationForScopes` and kept in memory only (backup.dart:127-129). Offline-block test NOT run (no device).

Crypto review notes

Item	Result
PIN hash	PBKDF2-HMAC-SHA256, 150k, random 16-byte salt per `setPin`; legacy SHA-256 hash auto-upgraded (lock.dart:117-127)
Compare	length check then XOR-accumulate: constant time per length (fine)
Recovery code	16 chars from 32-symbol alphabet = 80 bits via `Random.secure`; hashed with its own salt; guesses share the PIN `fails` counter and lockout (lock.dart:130-141) - good
Lockout	5 free misses, then every further miss locks 30 s, doubling each 5 misses, cap 3600 s (matches manual §8 wording closely: the first 30 s lock applies to each of misses 5-9). Worst-case exhaustive search of a 4-digit PIN ~80 days
PIN length	4-12 digits (`setupPin`, `_forgot`); 4-digit PINs are weak only if secure storage is extracted
Backup container	`PGMKENC1 | salt16 | nonce12 | ct | tag16`, fresh salt+nonce per file, key per file
Plain DB at rest	not encrypted - owner decision 2026-10-12, do not re-propose (PGM-214 note only)
Secure storage options	defaults (see PGM-200)

NOT tested

Anything needing a device/emulator (FLAG_SECURE behaviour, recents thumbnail, notification lock-screen visibility, clipboard behaviour, offline/airplane run, real Keystore reset); dependency CVEs (`dart pub audit` does not exist in this SDK; `dart pub outdated` shows no discontinued/retracted packages, only 4 minor-behind transitive deps; `sqlite3_flutter_libs ^0.6.0+eol` is an end-of-life marker package); the real keystore (apksigner on the released APKs only, per instructions); Google Cloud/OAuth console configuration; Drive-side behaviour.

Pagemark 0.7.0 - Release engineering audit (phase 10)

Commit `045e814` = tag `v0.7.0` (`git ls-remote --tags origin`), CI run 38330000180 on that commit: success. IDs PGM-220..PGM-229, PGM-231. Evidence: `script pgm220_release_verify.sh` (published assets of v0.4.2, v0.5.0, v0.7.0 downloaded from this repo's releases into the scratch dir, never executed), `script pgm200_apk_scan.py`, `auditor`, `code`.

Version consistency (all agree)

Source	Value
`pubspec.yaml`	`0.7.0+10`
APK arm64 / armv7 (aapt2 badging)	versionName `0.7.0`, versionCode `2010` / `1010` (Flutter split-per-abi adds 2000/1000)
Earlier releases	0.4.2 = 2006/1006, 0.5.0 = 2008/1008 -> monotonic, in-place upgrade OK
git tag / GitHub release	`v0.7.0`, tag commit == `HEAD` (045e814), release not draft/prerelease, "Latest"
CHANGELOG	`## [0.7.0] - 2026-10-12`; APK-bundled `assets/flutter_assets/CHANGELOG.md` is byte-identical to the repo file
Settings footer / About	`PackageInfo.fromPlatform().version` (branding.dart:66-70) - dynamic, cannot drift
Docs	USER_MANUAL, PACKAGE_OVERVIEW, RELEASE_NOTES say 0.7.0; **INSTALL_MANUAL says 0.5.0** and its PDF too (see DOCS_TRUTH PGM-240)
User-Agent	`Pagemark/0.3` in `lookup.dart:29` (stale cosmetic, PGM-229)

Published assets

Check	Result
Local build == published	sha256 of `build/app/outputs/flutter-apk/Pagemark-0.7.0-{arm64,armv7}.apk` equals GitHub asset digests `9c158c19...977d` / `9629e218...9719`; sizes 31,437,855 / 27,504,279
Signer	`CN=Pagemark, O=AxialForge`, SHA-1 `39:04:59:AD:24:0F:35:99:4B:CD:A5:86:81:AF:9C:21:8C:FD:27:F7` on v0.4.2, v0.5.0, v0.7.0 (both ABIs for 0.7.0), SHA-256 `26b4a423...ac44` identical -> in-place upgrade across releases is sound. Same SHA-1 as INSTALL_MANUAL/DRIVE_SETUP/ps1
Schemes	v2 only (v1 absent, v3/v3.1 absent). Fine for minSdk 24 (v2 is Android 7.0+). No v3 lineage, so the key can never be rotated (PGM-221)
SDK levels	minSdk 24, targetSdk 36, compileSdk 36
Debuggable / sources	no `debuggable`; no `.dart/.java/.kt` sources, `.jks`, tests or mapping inside the APK; `META-INF` holds only library license/version stubs; `classes.dex` + `classes2.dex`, R8 on (a `mapping.txt` exists locally)
ABIs	arm64-v8a (31 MB) and armeabi-v7a (27 MB) published. x86_64 built locally (33.9 MB) but **not published** (PGM-227)
16 KB page size	`zipalign -c -P 16 -v 4` OK for every `.so` in arm64 and armv7 APKs (v0.4.2, v0.5.0, v0.7.0); ELF PT_LOAD `p_align` = 16384 or 65536 for all arm64 libs (`pgm200_apk_scan.py`). Android 15+ 16 KB devices OK (PGM-226)
Secrets/personal data in package	none (`pgm200_apk_scan.py`: no 192.168, no owner name/email, no keys)
Size sanity	30-31 MB per APK (ML Kit barcode models ~ 3 .tflite + `libbarhopper_v3.so` 10 MB dominate); fine
Release notes on GitHub	not inspected beyond existence (read-only `gh release view` shows assets only)

Findings

PGM-220 INFO - signing identity and asset integrity verified

See table. Evidence `script pgm220_release_verify.sh`.

PGM-221 INFO - single signing key, no rotation lineage, one backup location

Only v2 signatures exist, so Android 9+ APK Signature Scheme v3 key rotation is unavailable; the keystore `pagemark-release.jks` + `key.properties` (plaintext passwords) are copied by `tool/backup-to-nas.ps1` to one NAS share, "the ONLY copy outside this PC" (script header, line 10). IB-80 in ROUNDING_OUT is marked fixed ("copy on NAS") but this is still two copies in the same house. Loss = every user must uninstall (data loss) to upgrade. Not a suggestion to buy anything: just keep an offline copy (USB) and note the passwords separately. I did not inspect the keystore (rule 2).

PGM-222 MEDIUM - release build/publish is manual and unscripted; asset naming is load-bearing and undocumented

- README/INSTALL_MANUAL say `flutter build apk --release --split-per-abi`, which produces `app-arm64-v8a-release.apk` / `app-armeabi-v7a-release.apk` (confirmed in `build/app/outputs/flutter-apk`). The published names are `Pagemark-x.y.z-arm64.apk` / `-armv7.apk`; the rename, signing check, GitHub upload and the `PAGEMARK_SCREENSHOTS` exclusion are done by hand. `Updater.pickAsset` (updater.dart:70-83) matches the substrings `arm64` and `armv7`: Flutter's default `armeabi-v7a` name does **not** contain `armv7`, so a release uploaded with default names would leave every 32-bit phone with `canInstall == false`.
- `tool/backup-to-nas.ps1` ends with "see ... tool\build.ps1" - that file does not exist (`git ls-files tool` = one file).
- CLAUDE.md "Release" says to attach APKs "by hand until a Flutter workflow exists"; the Roadmap section still lists "A Flutter CI workflow" as unbuilt though `ci.yml` exists (PGM-244).
- Fix: add `tool/release.ps1` (set `JAVA_TOOL_OPTIONS`, build, rename, `apksigner verify` against the expected SHA-1, `zipalign -c -P 16`, refuse `PAGEMARK_SCREENSHOTS`, write SHA-256 list) and document it in CLAUDE.md. Verify: run it on a clean checkout and compare with `script pgm220_release_verify.sh`.

PGM-223 LOW - CI scope and pinning

`ci.yml` runs on push to main and PRs: `pub get`, build_runner + `git diff --exit-code lib/db.g.dart`, `flutter analyze --no-fatal-infos`, `flutter test`, `flutter build apk --debug`. It does not (a) build `--release` (so R8/minify/desugaring regressions are first seen on the owner's PC), (b) run on tags, (c) attach artifacts. Actions are pinned to major tags (`checkout@v4`, `flutter-action@v2`, `setup-java@v4`), not SHAs, and Flutter is `channel: stable` unpinned while README says "Flutter 3.47+". The documented release flow ("CI proves analyze/test/debug-build, signed APKs local") matches what CI does. Last CI failure was on `2a12a91` (fixed by the next commit); tagged commit is green.

PGM-224 LOW - dependency hygiene

`riverpod` and `flutter_riverpod` are in `pubspec.yaml` but no file in `lib/` imports them (CLAUDE.md says "no state-management package"); `sqlite3_flutter_libs: ^0.6.0+eol` is the end-of-life marker release. `dart pub outdated`: only transitive minors behind (cross_file, cupertino_icons 2.0, material_color_utilities, test_api); nothing discontinued. No offline vulnerability scanner exists for pub (`dart pub audit` not in this SDK) - NOT RUN. `script`: `grep -rn riverpod lib` empty.

PGM-225 LOW - machine-specific build config committed

`android/gradle.properties` has two `org.gradle.jvmargs` lines; the second adds `-Djdk.net.unixdomain.tmpdir=C:/tmpj` (a Windows path) and wins. Harmless on the Ubuntu runner (CI is green) but any other contributor gets the property pointing at a non-existent folder. Also `-Xmx8G` heap on a 7 GB hosted runner. Move the tmpdir override to `JAVA_TOOL_OPTIONS`/user-level `~/.gradle/gradle.properties` (CLAUDE.md already says the client JVM needs the env var anyway).

PGM-226 INFO - 16 KB alignment passes

`zipalign -c -P 16 -v 4` and ELF PT_LOAD alignment (16384/65536) both pass for all native libs in all three inspected releases. `script pgm220_release_verify.sh`, `pgm200_apk_scan.py`.

PGM-227 INFO - x86_64 not published

`pickAsset` can select `x86_64`, but no such asset exists; emulators / x86 Chromebooks cannot install via the in-app updater (`apks.length == 2` so the single-APK fallback does not apply) and the README only mentions arm64. Matches the instruction to note it; add a README line.

PGM-228 INFO - R8 mapping is local only

`build/app/outputs/mapping/release/mapping.txt` is git-ignored and `backup-to-nas.ps1` excludes `build\`, so native-side symbols of past releases cannot be recovered. Low value (no crash reporter), noted for completeness.

PGM-229 LOW - repo hygiene

- `android/.kotlin/` is untracked and not ignored (shows in `git status`); add to `.gitignore`.
- `.git` is 38 MB because five PDFs (2.5 MB + 2.1 MB + ...) are re-committed on each docs rebuild; acceptable, but PR template says "No new file committed that CI could rebuild" (PDFs need local Edge, so allowed).
- Stale `Pagemark/0.3` User-Agent (`lookup.dart:29`).
- No `.github/workflows` release job, no `SETUP.md` leftover (good), `CONVENTIONS.md` present, LICENSE MIT 2026 "Joseph Costarella (AxialForge)".
- Tracked: no APKs, keystores, `local.properties`, `.idea`, `build/` (verified `git ls-files`). `ios/` project is tracked (40 files, unbuilt - fine).

PGM-231 INFO - upgrade path and stored keys

- Drift schema `currentSchema = 4`; `onUpgrade` steps 1->2 (deletedAt + 3 indexes), 2->3 (seriesNumber, currentPage, shelves, book_shelves), 3->4 (seriesTotal, heat, contentNotes, quotes). Every table/column in `db.dart` (and `lib/db.g.dart`, CI checks it is regenerated) is created either by `createAll` or one of these steps. `Exporter.inspect` accepts `user_version <= AppDb.currentSchema` (export.dart `ver > AppDb.currentSchema` rejects newer), so restore and schema agree. Missing: no index on `quotes.book_id` (minor perf).
- SharedPreferences keys in use: `theme, hide_locked, app_lock, lock_delay, adult_fields, seen_version, upd_auto, upd_last, vault_lookup_ok, goal_<year>, lib_{m,v}_{shelf,status,sort,skin,group,format}, bk_on, bk_freq, bk_wifi, bk_cid, bk_acct, bk_ok, bk_err, bk_fail, bk_hash, bk_sched`. Secure storage: `mode, pin_hash, pin_salt, rec_hash, rec_salt, fails, lock_until, bk_pass`, plus legacy `pin, salt` (v0.1.0, still read and upgraded). No rename between releases strands data; legacy keys are migrated on first successful PIN. Theme ids `light_him/...` intentionally kept. Note `bk_hash` signature changed meaning in 0.6.0 (adds covers signature) - only causes one extra upload.

NOT tested

Installing/upgrading APKs on a device, `adb` anything, building from a clean checkout (README steps judged from files; `flutter test` was run: +193 passed, ~1 skipped (seed tool), all green), CI release behaviour on tags, the keystore itself, GitHub release body text, antivirus/Play Protect behaviour.

Pagemark 0.7.0 - Docs truth (phase 11)

Documents checked: `README.md`, `docs/release-package/{USER_MANUAL,INSTALL_MANUAL,PACKAGE_OVERVIEW,RELEASE_NOTES}.md` (+ the five PDFs, text-extracted with `script pgm230_pdf_scan.py`), `docs/PRIVACY.md`, `docs/DRIVE_SETUP.md`, `docs/ROADMAP.md`, `docs/ROUNDING_OUT_REPORT.md`, `CLAUDE.md`, `CHANGELOG.md`. Checked against `lib/`, the real merged manifest of the v0.7.0 APK, `flutter test` (run: +193 passed, 1 skipped), and the published GitHub releases. IDs PGM-240..PGM-249.

Verified TRUE (no finding)

- Menu paths and labels: Settings -> Updates / Theme / Import / Export (main library only) / Google Drive backup / Database (includes locked books) -> Export database file, Restore from database file, Covers, Trash / Privacy -> Lock now, Lock after leaving the app, Lock the whole app, Heat level and content notes, Hide the Locked tab, Set or change PIN, Remove lock / Diagnostics (ui.dart:1210-1355). Book menu: Save cover on this phone, Choose cover from gallery, Remove saved cover, Move to Trash (ui.dart:899-902). Library -> Trash only inside the vault (ui.dart:374).
- Numbers: 5 Drive backups kept (`keepBackups = 5`), Trash 30 days (`trashDays = 30`), safety copies newest 3, lock delays Immediately/1/5/15 min (`lockDelayChoices`), PIN 4-12 digits, lockout 30 s doubling every 5 misses cap 1 h (lock.dart:71-81), 5 free attempts, update check at most once per 24 h (`autoCheckUpdates`), `ReadEditor` rejects finished < started, update download verifies size + SHA-256, "Android 7.0 or newer" = minSdk 24, "193 automated tests" = suite result (+193, 1 skipped seed tool; `grep` finds only 121 literal `test(` calls because several are generated in loops - do not "fix" the number by counting source), CHANGELOG shape matches the in-app renderer, bundled CHANGELOG == repo CHANGELOG, signing SHA-1 in INSTALL_MANUAL/DRIVE_SETUP == real APK certificate, package name `com.axialforge.pagemark` == APK.
- Network promises in README, manual §1/§16 and PRIVACY.md match the code (PGM-217). Screenshots viewed (library, backup, about, settings, updates, updates-available, quotes) show invented sample books only.
- PRIVACY permission paragraph lists the main permissions correctly; `allowBackup=false` claim is true in the shipped manifest.

Findings

ID	Sev	Where	Claim	Reality
PGM-240	MEDIUM	`INSTALL_MANUAL.md` header + PDF; §4	"Version 0.5.0"; "Pagemark does not ask for storage, photo/media or **notification** permissions"	stale by two releases (the PDF `Pagemark-Install-Manual.pdf` and the combined `Pagemark-Documentation.pdf` also say 0.5.0). The shipped manifest declares `POST_NOTIFICATIONS` (0.4.3), and the permissions table omits Notifications (and the merged VIBRATE/WAKE_LOCK/BOOT_COMPLETED/FOREGROUND_SERVICE_SHORT_SERVICE that PRIVACY.md also only covers as "background work"). `aapt2 dump badging` evidence.

ID	Sev	Where	Claim	Reality
PGM-241	MEDIUM	`PACKAGE_OVERVIEW.md` Tier 3	"Data model (schema 3)", "Versioned migrations (1->2->3)", "Release builds are not minified", "No failure notification yet", "Roadmap highlights: Goodreads/StoryGraph import, grid cover view, quotes ..., SQLCipher, backup failure notifications"	Schema is 4 (quotes table, series_total, heat, content_notes; migrations 1->2->3->4); release builds ARE R8-minified (CLAUDE.md gotcha + `mapping.txt`); failure notifications shipped in 0.4.3; import/quotes/series totals shipped; SQLCipher was declined by the owner on 2026-10-12 (CLAUDE.md, CHANGELOG 0.7.0 "Decided"). The "Known limits (0.7.0)" list itself contradicts the manual/changelog. Also omits quotes/author/covers/import tables from the data-model list.
PGM-242	MEDIUM	`DRIVE_SETUP.md` Notes	"Backups include locked books and are not encrypted by Pagemark"	Passphrase encryption (AES-256-GCM) exists since 0.2.0 and the manual/PRIVACY recommend it. The setup guide an owner reads first states the opposite and does not mention the passphrase toggle. (Understates protection; not data-losing.)
PGM-243	MEDIUM (cross-ref)	`USER_MANUAL.md` §8 / §15, `PRIVACY.md`, CLAUDE.md	"temporary export files are deleted" when the vault closes; Diagnostics "never contains book titles or your thoughts"	False on the failure paths: plaintext copies stay in `cache/share_plus` and `cache/file_picker` (**PGM-203**), and exception text with SQL parameters lands in the log (**PGM-201**). Following the manual's advice to "Copy it when asking for help" can disclose titles. Rated in the security register; listed here because the docs make the promise.
PGM-244	LOW	`CLAUDE.md`	Directory map "manifest has INTERNET/USE_BIOMETRIC/CAMERA"; "Roadmap (unbuilt): A Flutter CI workflow...; Reading goals/streaks, series grouping, CSV/Goodreads import"; "No CI builds the APK yet" ; `tool\build.ps1` referenced by backup script	Manifest also has REQUEST_INSTALL_PACKAGES and POST_NOTIFICATIONS; `ci.yml` exists; goals, series, import all shipped; `tool/build.ps1` does not exist (PGM-222). The lib/ map omits `app_lock, backup_errors, book_extras, branding, covers, import_ui, importer, notifier, selection, text_utils, widgets`. CLAUDE.md is the highest-value file; keep it current.

ID	Sev	Where	Claim	Reality
PGM-245	LOW	`USER_MANUAL.md` line 5 "Screenshots ... captured from the Android app (0.7.0)"; INSTALL/README	all screenshots are 0.7.0	`about.jpg` and `updates.jpg` show "0.4.1", `settings.jpg` shows 0.4.2 (no Import/Covers/Privacy rows visible), `updates-available.jpg` "Installed 0.4.1", `quotes.jpg` shows the "Updated to Pagemark 0.5.0" toast. Latest git touch of `about.jpg`: 2026-10-11 (b57027d). The remaining ~25 screenshots were not individually dated (not visually opened).
PGM-246	LOW	`README.md`, `docs/ROADMAP.md`	"the full 330-item backlog is in ROUNDING_OUT_REPORT.md "	the report holds 190 feature + 190 issue + 50 UI entries = **430** (`grep -c`). `ROADMAP.md` also says "44 tests" and "Flutter 3.47+" for a history document written after v0.4.1 - mark it historical.
PGM-247	LOW	`USER_MANUAL.md` structure	numbered §5, §6, then §5b, §6b, §10b after §6 "Library styles"	out-of-order headings (5b "Quotes, authors..." sits after 6 "The Library"); the PDF inherits it. Renumber at the next doc rebuild.
PGM-248	MEDIUM	`ROUNDING_OUT_REPORT.md` "Fixed in" lines	sample of 25 IDs checked against code (below)	3 not-fully-true: **IB-10** (share temp files stay in cache - only top-level files wiped; PGM-203), **IB-16** (after removing the PIN "whoever has the phone becomes the vault owner" - still true by design, subtitle admits it; PGM-207/PGM-200), **IB-80** (keystore "exists in one place": now two places in the same home; PGM-221). **IB-44** claims size/checksum: size only (Drive `md5Checksum` is not compared).
PGM-249	LOW	`USER_MANUAL.md` §8 "Remove lock"	"Remove lock (which asks for the current PIN first; locked books stay in the locked library)"	true, but omits that afterwards *anyone* can set a new PIN and read them, and that a stale "Lock the whole app" switch stays on (PGM-207). The in-app subtitle is clearer than the manual.

Sample check of ROUNDING_OUT "Fixed in" claims (25 IDs)

Confirmed in code/APK: IB-02 (PBKDF2), IB-03 (lockout), IB-05/06 (relock + popUntil), IB-07 (FLAG_SECURE), IB-09 (`lockedCache.emptyCache`), IB-12 (`allowBackup=false`, verified in APK), IB-13 (opt-in encryption), IB-19 (`foreign_keys=ON`), IB-21 (`integrity_check`), IB-22 (safety copy), IB-24 (newer-schema rejected), IB-25 (`busy_timeout 5000`), IB-33 (duplicate warning), IB-43 (digest skip), IB-47 (`bk_sched` guard), IB-48 (battery guidance, backup_page.dart:228), IB-81 (PRIVACY.md), IB-87 (scanner `errorBuilder`), IB-89 (`SystemNavigator.pop`), IM-07 (`safeCell`), IS-50/51 (format version, timestamped filenames), FB-45 (restore/import safety copy; bulk delete uses Trash+Undo instead). Not-fully-true: IB-10, IB-16, IB-80, IB-44 (see PGM-248).

Other claims worth knowing

- README "Install: Download the arm64 APK ... Android 7.0 or newer": true. README build steps `flutter build apk --release --split-per-abi` work but produce differently named files than the release (PGM-222).
- `RELEASE_NOTES.md` is a reformatted copy of `CHANGELOG.md` (same sections/bullets, bullets un-wrapped); the 0.7.0 and 0.6.0 text matches. The "Unreleased" empty block exists only in CHANGELOG (fine).
- PRIVACY.md "applies to 0.4.3 and later", updated 2026-10-12: still accurate except the log promise (PGM-201) and it does not name the GitHub asset CDN host.
- `DRIVE_SETUP.md` embeds the owner's *debug*-key SHA-1 ("on this PC"): public information, harmless, but machine-specific.

NOT tested

Every individual manual step on a device (no emulator use), visual match of the ~25 screenshots not opened, in-app help text beyond Settings strings, Install-manual steps on a clean phone, PDF layout.

Pagemark 0.7.0 - Compatibility matrix (phase 12, static part)

Source: merged manifest and resources of the published `Pagemark-0.7.0-arm64.apk` (`aapt2 dump xmltree/badging/resources`), `lib/`, `android/` sources. **Nothing here was run on a device or emulator** (off-limits to this auditor); every row is "static" unless noted. IDs PGM-250..PGM-254.

Platform facts

`minSdk 24 (Android 7.0)`, `targetSdk 36 (Android 16)`, `compileSdk 36`; Flutter 3.47; APK signing v2 only (valid from API 24); ABIs arm64-v8a + armeabi-v7a published (x86_64 not published, PGM-227); `extractNativeLibs=false`; 16 KB aligned (PGM-226).

Area	Implication / what the code does	Static verdict
Predictive back (Android 13+, default on for targetSdk 36)	`android:enableOnBackInvokedCallback="true"` is in the merged manifest. App uses `PopScope(onPopInvokedWithResult)` for the app-lock gate (Back leaves the app, `SystemNavigator.pop`)	OK on paper; back-gesture animation + gate behaviour NOT RUN
Edge-to-edge enforcement (Android 15+, targetSdk 35+)	No `SystemChrome`/inset code in `lib/`; `windowSoftInputMode=adjustResize`; launch themes `Theme.Light.NoTitleBar` / `DeviceDefault.NoActionBar`; screenshots from the emulator show correct top/bottom padding (those are 0.4-0.5 builds)	Likely OK via Flutter embedding; NOT RUN on API 35/36 (PGM-253)
Display cutout	no `windowLayoutInDisplayCutoutMode`	default; NOT RUN
Notification permission (API 33+)	`POST_NOTIFICATIONS` declared; requested when the user turns on automatic backup (`backup_page.dart:202`); denial only suppresses the failure notice (`Notifier` try/catch)	OK
Foreground service types (API 34+)	WorkManager `SystemForegroundService` declared with `foregroundServiceType=0x800` (shortService) and `FOREGROUND_SERVICE_SHORT_SERVICE` permission present	consistent; app never starts a foreground service itself
Background execution limits / Doze / OEM killers (API 31-36)	Periodic WorkManager, `NetworkType.unmetered/connected`, exponential backoff; in-app battery-optimisation guidance and button (`backup_page.dart:228-233`); manual §11 warns about delay	OK, timing NOT RUN
Exact alarms	not used (`SCHEDULE_EXACT_ALARM` absent)	n/a
Storage / media permissions	none: `READ_EXTERNAL_STORAGE`, `READ_MEDIA_*` removed with `tools:node="remove"`; gallery cover uses `image_picker` (system Photo Picker via `photopicker_activity` metadata); backups via SAF `file_picker`	OK
Install unknown apps	`REQUEST_INSTALL_PACKAGES`; `OpenFilex` returns `permissionDenied` -> friendly message. On API 24-25 "Unknown sources" is one global switch, whereas INSTALL_MANUAL §3 step 2 describes the Android 8+ per-app switch (PGM-252)	LOW doc
Camera	`uses-feature android.hardware.camera required=false`; scanner has a permission-denied/`errorBuilder` state; tablets/Chromebooks without camera can still install	OK

Area	Implication / what the code does	Static verdict
Biometrics	`USE_BIOMETRIC` + legacy `USE_FINGERPRINT`; `FlutterFragmentActivity`; `local_auth` default allows device credential fallback; weak-biometric warning exists	OK
Desugaring / java.time on API 24-25	`isCoreLibraryDesugaringEnabled` + `desugar_jdk_libs 2.1.4`	OK
Large screens / foldables / orientation	no `screenOrientation`, no `resizeableActivity=false` (resizable by default at targetSdk >= 24); `configChanges` covers orientation, screenSize, smallestScreenSize, screenLayout, density, uiMode, layoutDirection, fontScale; Android 16 ignores orientation/aspect opt-outs on >= 600 dp anyway	OK statically; tablet layouts of the five Library styles NOT RUN (PGM-254)
Multi-window / split-screen	resizable; `AppLifecycleState.paused` is not delivered to the unfocused-but-visible window on Android 10+ multi-resume devices, so the delay-0 relock may not fire while another app is focused alongside	edge case, NOT RUN (PGM-254)
Large text	`test/v043_ui_test.dart` draws every Library style at 200 % (CLAUDE.md gotcha); suite green	OK
Dark mode	six themes; launch themes have `values-night` / `values-night-v31` variants	OK
Per-app language / RTL	no `localeConfig`, no `supportsRtl` attribute; no `flutter_localizations/localizationsDelegates/supportedLocales` in `main.dart/pubspec.yaml`, i.e. the UI is English only and Flutter never receives an RTL locale (PGM-250)	INFO
Locale-dependent formats	`DateFormat.yMMMd()` / `.add_jm()` (ui.dart:39, backup_page.dart:129,264, updater_ui.dart:140,185) never pass a locale and no `initializeDateFormatting` is called, so dates are always en_US ("Oct 12, 2026") and times always 12-hour with AM/PM even on 24 h / non-US phones; decimals use `toStringAsFixed` (always "."), e.g. "3.5" for a comma-decimal phone; filenames use fixed `yyyyMMdd-HHmm`	LOW (PGM-250)
Time zones / clock	wall-clock `DateTime.now()` for lockout/delay (PGM-206), dates stored via Drift `dateTime` (local)	see security
ABIs	arm64, armv7 only; x86_64 devices cannot use the in-app updater (PGM-227)	INFO
Android 7.0 (API 24) TLS roots	not verifiable statically (GitHub, Google, openlibrary.org certificate chains on a 2016 trust store)	NOT RUN

Findings

- **PGM-250 LOW** - Dates/times and number formats ignore the device locale (always en_US, 12-hour clock); the app has no localisation. Evidence: `code ui.dart:39`, `backup_page.dart:129`, `updater_ui.dart:140`; `grep localizationsDelegates|supportedLocales|flutter_localizations` empty. Fix options: declare `supportedLocales: [Locale('en')]` explicitly and document "English only", or pass `Localizations.localeOf(context).toString()` and add `flutter_localizations` + `initializeDateFormatting`. Verify: device set to `de-DE`, 24 h clock: Updates page "Last checked" should show 24 h.
- **PGM-251 INFO** - English-only UI means RTL is moot today; `android:supportsRtl` is unset (framework default false). Revisit only if localisation is added.
- **PGM-252 LOW** - INSTALL_MANUAL step 2 ("turn on Allow from this source") is Android 8.0+ behaviour; on Android 7.0/7.1 (supported minimum) the user must enable global "Unknown sources". `code docs/release-package/INSTALL_MANUAL.md:27`.

- **PGM-253 INFO** - Edge-to-edge (API 35+), predictive back animation and cutout handling cannot be confirmed statically; the device auditor should run the three screens with the keyboard open (Add book search, ReadEditor, PIN gate) on an API 35/36 image.
- **PGM-254 INFO** - Tablet/foldable layout of Cover wall / Bookshelf / Spines and the multi-window relock edge case are unverified.

NOT run

Everything on a device or emulator (API 24, 29, 33, 35, 36 images; tablet/foldable; 24-hour and non-US locale; display scaling; font scale beyond the existing widget tests; Android 15/16 enforcement behaviour). Windows/other Flutter/SDK versions beyond the machine's Flutter 3.47 / SDK 36.0.0 build-tools.